ダイナミックリスクアセスメントにおける攻撃尤度推定手法に注目したセキュリティリスク評価式の検討

川西康之 [123a)]　西原秀明 [1]　吉田博隆 [1]　井上博之 [13]

概要：従来のサイバー攻撃に対するリスクアセスメントはネットワーク構成図などを基にリスクの静的分析を行っていたが，未知の脆弱性の露見や攻撃手法の確立などの急激な環境変化に対応できる柔軟な分析は想定されていなかった．これに対し近年，環境の変化に注目するダイナミックリスクアセスメント(DRA)と呼ばれる研究が行われている．

ベイジアンネットワークは事象の因果関係と起こりうる尤度を可視化できるツールで，これをサイバー攻撃に対するリスクアセスメントでアタックグラフに適用し，環境の変化による攻撃の手段や経路を評価するものがベイジアンアタックグラフ(BAG)である．尤度の推定にはCVSSなどのリスク評価式を用いた先行研究が多い．

本研究では，この攻撃尤度推定に用いるリスク評価式に着目し，従来のCVSSに加え，より攻撃環境に沿った評価を反映できるよう，コモンクライテリアで評価に用いられるAttack Potentialと併用する手法を提案する．これにより攻撃における環境の変化を柔軟に評価し，対策の優先度をより的確に決めることが可能になる．

キーワード：工場セキュリティ，リスク分析，ベイジアンアタックグラフ，CVSS，Attack Potential

A Study of Security Risk Assessment Formulas focusing on Attack Likelihood Estimation Methods in Dynamic Risk Assessment.

YASUYUKI KAWANISHI[123a)]　HIDEAKI NISHIHARA[1]
HIROTAKA YOSHIDA[1]　HIROYUKI INOUE[13]

Abstract: A traditional risk assessment for cyberattacks has relied on static risk analysis based on network diagrams and other data. However, this approach has not been designed to rapid environmental changes such as the discovery of unknown vulnerabilities or the establishment of new attack methods. In recent years, research has focused on dynamic risk assessment (DRA), which emphasizes environmental changes.

Bayesian network is a tool that visualizes causal relationships and likelihoods of events. Applying this to attack graphs in cyberattack risk assessments results in a Bayesian attack graph (BAG) that evaluates attack methods and paths in response to environmental changes. Many previous studies have used risk assessment formulas such as CVSS for likelihood estimation.

This research focuses on the risk assessment formulas used for attack likelihood estimation and proposes a method that combines CVSS with Attack Potential which is used for evaluation in Common Criteria to better reflect the attack environment. This allows for a more flexible evaluation of environmental changes in attacks and enables more accurate prioritization of countermeasures.

Keywords: Factory security, risk analysis, Bayesian arrack graph, CVSS, attack potential

1. はじめに

近年，工場や重要インフラ施設などの産業制御システムはIT化が進められており，その結果としてサイバー攻撃を受ける対象になり，その被害も大きなものとなっている．例えば2015年におけるウクライナの電力グリッドへの攻撃は，インターネットからの侵入から1年近い長期間の潜伏・調査期間を経て大規模停電を引き起こし，22.5万人に影響を及ぼした[1]．このような持続的な攻撃スキームはAPT攻撃 (Advanced Persistent Threat Attack)と呼ばれており，工場や重要インフラ施設に対し繰り返し行なわれてきた．

これらサイバー攻撃のリスクを低減するためのリスクアセスメントについて，様々なフレームワークが考案されてきた．システムをモデル化してリスクを分析する手法はモデルベースリスクアセスメントとして産業制御システム向けの標準にも採用されている．

しかし従来のモデルベースリスクアセスメントは，システム設計仕様を基に生成したモデルによる静的なリスク分析のみ行っているため，運用形態の変化，新たな脆弱性の発見，攻撃の進行などによるリスクの変化に即時対処することが難しい．そこで従来手法では行えない分析手法として，リスクをリアルタイムの情報から脅威を特定，評価し，そのリスクを最適に軽減する方法について迅速な意思決定を行える手法の研究が近年検討されている．この手法はダイナミックリスクアセスメントと呼ばれている．

文献[2]はこの新しい手法に注目し，その特徴を「組織の業務に対するリスクを動的かつほぼリアルタイムで継続的

1　(国研) 産業技術総合研究所 住友電工―産総研サイバーセキュリティ連携研究室，〒563-8577 大阪府池田市緑丘 1-8-31, SEI-AIST Cyber Security Cooperative Research Laboratory, AIST, 1-8-31 Midorigaoka, Ikeda, Osaka 563-8577.
2　住友電気工業株式会社，〒541-0041 大阪府大阪市中央区北浜 4-5-33, Sumitomo Electric Industries, Ltd., 4-5-33 Kitahama, Chuo-ku, Osaka, Osaka 541-0041, Japan.
3　京都産業大学 情報理工学部，〒603-8555 京都府京都市北区上賀茂本山, Faculty of Information Science and Engineering, Kyoto Sangyo University, Motoyama, Kamigamo, Kita-ku, Kyoto, 603-8555, Japan.
a)　kawanishi.yasuyuki@aist.go.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

に特定し評価するプロセス」であり，「環境から得られるあらゆる種類のリアルタイムデータを入力として使用し，それらに基づいてリスクを計算するシステム，モデル，またはフレームワーク」であると定義している．そしてその定義を満たす論文 50 編をレビューし，技術的な観点から多くのアプローチがあることを示した．

ダイナミックリスクアセスメントのアプローチで研究テーマに比較的多く選ばれているものが，ベイジアンネットワークをアタックグラフに適用したベイジアンアタックグラフである．サイバー攻撃の因果関係や依存関係の可視化をベイジアンアタックグラフで行いつつ，攻撃がどのように浸透するかを推測できる一方で，設計時に想定していなかった攻撃を受けた際の当初の推測の見直しを行えるという 2 つの分析手法が研究されている．

本研究はこれら 2 つの分析手法のうち，前者に着目する．つまりベイジアンアタックグラフの因果関係に沿った順方向での分析手法であり，システムを巡る環境の変化が起きた場合に，リスクの変化を逐次数値で見ることができるという特徴がある．例えばシステムを構成する機器に新たな脆弱性が見つかった場合，ハッキングによりある機器への侵入手段が確立された場合などの急な環境の変化に対し選択される攻撃経路がどう変わるか，最終目標の資産への攻撃が成功する尤度はどう変わるかを評価することができる．

そして本研究は上記ベイジアンアタックグラフの順方向分析の尤度推定に用いる確率モデルについて提案を行う．先行研究では CVSS (Common Vulnerability Scoring System) や EPSS(Exploit Prediction Scoring System)などの脆弱性評価手法をベースとした確率モデルを用いている．この場合ネットワーク内の機器が既知の脆弱性を持っているケースだと扱いやすいが，脆弱性を持っているか未知な対象を扱う場合は適用が難しいと思われる．また攻撃者の能力や環境を推測できるメトリックを CVSS などから拡張して用いているが，評価におけるそれらメトリックの整合性や妥当性に課題があった．先行研究では CVSS のメトリックの拡張や新たなメトリックの追加で対応している．本研究ではより柔軟に対応できる CC CEM (Common Criteria Common Methodology for Information Technology Security Evaluation)の Attack Potential の評価式をベースにした確率モデルを CVSS と併用する手法の提案を行う．前段の課題に対し柔軟に対応できる CC CEM で解決を図る．

2 章で準備を行い，3 章で課題と課題を解決する本提案手法について述べ，4 章でケーススタディを用いて詳細を説明する．そして 5 章でディスカッションを行い，6 章で結論を述べる．

2. 準備

2.1 ダイナミックリスクアセスメント

組織の業務に対するリスクを動的かつ，ほぼリアルタイムで継続的に特定し評価するプロセスがダイナミックリスクアセスメントである．環境から得られるあらゆる種類のリアルタイムデータを入力として使用し，それらに基づいてリスクを計算することを特徴としている．

文献[2]はダイナミックリスクアセスメントの手法について以下のような技術的カテゴリを定め，調査した論文 50 編のレビューと分類を行っている:

(1) AI/ML 技術を利用したアプローチ(24 編)
  (ア) ベイジアンネットワークを利用(11 編)
  (イ) アタックツリーを利用(7 編)
  (ウ) ニューラルネットワークを利用(3 編)
  (エ) 人工免疫理論を利用(2 編)
  (オ) その他(1 編)
(2) 数式を利用した数学的アプローチ(13 編)
(3) その他のフレームワークからのアプローチ(13 編)

本研究は(1)の(ア)と(イ)を組み合わせたベイジアンアタックグラフを用いたアプローチに着目し，リスクの大きさを数値化する際の計算式に新たな観点を追加するものである．先行研究については 2.4 節で後述する．

2.2 ベイジアンネットワーク

攻撃シナリオの分析にベイジアンネットワークを適用し可視化したものが，ベイジアンアタックグラフである．ベイジアンネットワークとは，因果関係を確率により記述するグラフィカルモデルの 1 つで，因果関係の推論を図 1 のような有向非巡回グラフ構造により示すと共に，個々の変数を条件つき確率で表す，確率推論のモデルである．

ベイジアンネットワークは，以下のベイズの定理を回帰的に用いることで，矢印のどちらの方向にも発生確率を求めることができる．例えば図 1 右における事象 X と Y における確率は以下の式(1)の定理に従う．

$$\mathbf{P(X|Y)} = \mathbf{P(X)} \times \mathbf{P(Y|X)} / \mathbf{P(Y)} \quad (1)$$

ここで P(X)と P(Y)は事象 X および Y の発生確率(事前確率)，P(X|Y)は事象 Y が起きた条件での事象 X の条件付き発生確率，P(Y|X)はその逆で，事象 X が起きた条件での事象 Y の条件付き発生確率(尤度)である．式(1)は，式の右辺の確率が既知の場合に左辺を求めることが可能なことを示

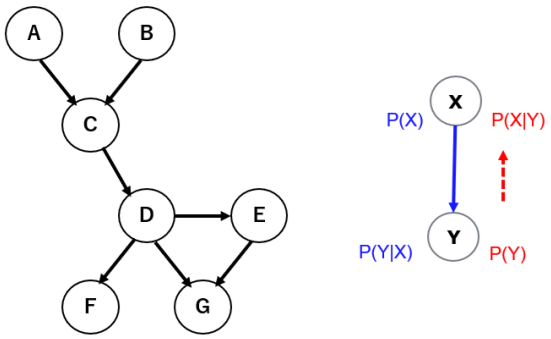


図1　ベイジアンネットワーク

© 2026 Information Processing Society of Japan

しており，「結果として事象 Y が起きている時にその原因が事象 X である確率(事後確率)」を算出できる．

2.3 CVSS (Common Vulnerability Scoring System)

共通脆弱性評価システム CVSS は，脆弱性の持つリスクの大きさを数値化するための評価手法として，共通脆弱性識別子 CVE (Common Vulnerabilities and Exposures)とセットで用いられている．これは被害を受けるシステム側の観点からネットワーク構造の複雑さや資産の重要性からリスクの大きさを数値化するものである．

現在脆弱性評価に用いられている CVSS は Ver.2 と Ver.3.1 の 2 通りがあるが，本論文では Ver.3.1 を取り扱う．Ver.3.1 のリスク評価式を式(2-1)〜(2-3)に示す:

$$\text{影響度} = 6.42 \times [1 - (1 - C) \times (1 - I) \times (1 - A)] \quad (2\text{-}1)$$

$$\text{攻撃容易性} = 8.22 \times AV \times AC \times PR \times UI \quad (2\text{-}2)$$

$$\text{リスク値Rr} = \min[(\text{影響度} + \text{攻撃容易性}), 10] \quad (2\text{-}3)$$

C，I，A: システムが保有する資産の重要度
それぞれ機密性，完全性，可用性に係る

AV: 侵入口の種別

AC: 攻撃の複雑さ

PR: 攻撃に必要な特権レベル

UI: 攻撃に必要なシステム利用者の関与

リスク値 Rr は 0 以上 10 以下の値を取り，値が大きいほどリスクが高いと評価される．

2.4 CVSS を尤度に利用したベイジアンアタックグラフ分析および先行研究

ベイジアンネットワークをアタックグラフに適用し，CVSS をベースに確率モデルとして結果の尤度や原因の推測を求める手法が提案されてきた[3]．CVSS スコアは攻撃成功確率そのものではないが，文献[4]にて，脆弱性における CVSS スコアと NVD (National Vulnerability Database)で確認されたその脆弱性への攻撃頻度は比例関係が見られることが主張された．そして文献[5][6]などで，CVSS スコアを正規化して確率に見立ててベイジアンアタックグラフの尤度の推移を見る研究が行なわれてきた．

本研究の先行研究としては文献[6]が最も近く，CVSS を環境の変化に対応して評価できるよう，一部拡張を行った評価式を提案している．

2.5 CC CEM と Attack Potential

コモンクライテリア(CC: Common Criteria)は，金融業界のセキュリティカードなどのセキュリティ製品を評価し認定する基準として，EU を中心に権威がある標準である．

CEM (Common Methodology for Information Technology Security Evaluation)[7]はコモンクライテリアで評価を行う際の手法を記述したもので，その中の Annex B (informative)にて脆弱性分析(Vulnerability assessment)コンポーネント AVA_VAN を評価する手法のひとつとして，Attack Potential が示されている．

Attack Potential に関しては業界(例えば IC チップ製造など)によりメトリックとランクの追加設定がなされている場合があるが，基本的には以下の 5 つの要素で攻撃者の能力や環境を評価する:

- **Elapsed Time(T):** 攻撃者が攻撃を成立させるのに要する時間
- **Specialist Expertise(Ex):** 攻撃者の技術的習熟度
- **Knowledge of TOE(K):** 攻撃対象に関する知識
- **Window of Opportunity(O):** 攻撃を行えるタイミングや時間枠の要否や程度
- **Equipment(Eq):** 攻撃を行うのに必要な機材(ソフトウェア/ハードウェア共)の入手や準備の容易性

これらの観点からランクに応じた点数を加算し，合計値により 5 段階でリスクを評価する．Attack Potential の取る値は 0 以上 34 以下の整数で，値が小さいほど攻撃者の能力や環境が充実しており，評価対象が攻撃を受けるリスクが高いとみなされる．

3. 先行研究の問題，提案方式，および貢献

3.1 本研究のスコープと先行研究の問題

本論文における研究のスコープは，ベイジアンネットワークを攻撃尤度の評価に適用したベイジアンアタックグラフであり，かつ攻撃尤度の指標に CVSS などのリスク評価式を用いた手法に関するものである．

本研究の先行研究は以下の 3 系統に分けられるが，それぞれに後述するような問題があると思われた:

1) CVSS や EPSS など，既存の機器やソフトウェアの持つ脆弱性で評価[8][9]
2) CVSS の一部メトリックの拡張で評価[5][6][10]
3) CVSS に新規独自メトリックの追加で評価[11]

まず 1)であるが，脆弱性評価値を確率モデルに適用する場合，ベイジアンアタックグラフのノードが「既知の脆弱性を持った機器」のみに限定され，ひとつの機器内での複数段の攻撃のような攻撃シナリオの詳細を分析することができない．また，未知の攻撃を想定した攻撃シナリオの分析手段が定められていない．

次に 2)であるが，文献[3][10]共に CVSS の現状評価基準(Temporal Metrics)の ECM (Exploit Code Maturity: 攻撃コードの成熟度)と RL (Remediation Level: 攻撃をどの程度是正できるかを示すレベル)を拡張して使用しているが，特に前者の ECM の評価基準を用いない独自解釈を依る点が問題である．また ECM については，評価の目安となる信頼できる情報源が不足しているため使うべきではないと近年提言があった [12]．さらに ECM，RL 共に評価が 4 段階あるものの，値の変動幅が狭く評価に明確な差が出にくいという問題もある．

© 2026 Information Processing Society of Japan

最後に 3)であるが，文献[11]では CVSS に多くの新規定義のメトリックを投入した結果，リスク評価式が原型を留めていない．そのことでリスク評価結果自体の信憑性に疑問がある．本研究のフォロワーが近年に至るまで現れていないこともあり，可能なら実績や権威のある評価式を応用できた方が望ましいと思われる．

以上をまとめると，先行研究に代わる以下のような要望事項を満たす手法が望まれる:

- 未知の脅威であっても攻撃者の能力やシステムの環境などで評価できるようにしたい
- 元のメトリックの定義から大きく外れる，もしくは多くの解釈を持たせ過ぎるような手法は避けたい
- 広く使用されていて，実績と権威のあるリスク評価式を取り入れたい

3.2 提案手法

そこで攻撃尤度を評価するための計算式に，CVSS に加え前述の Attack Potential を併用するように考案したのが，以下に説明する提案手法である．

あるノード N において，ネットワークトポロジや認証の有無により攻撃容易性が変化するなど，システム由来の要因が攻撃尤度に影響を与える場合，式(3-1)で表される f_N でノードを評価する．一方，熟練攻撃者が機器のリバースエンジニアリングで手法を確立し攻撃を成功させられるなど，攻撃者の能力や準備環境由来の要因が攻撃尤度に影響を与える場合，式(3-2)で表される g_N でノードを評価する．f_N および g_N は，共に 0 以上 1 以下の小数を取る．

ノード N の攻撃尤度は f_N もしくは g_N いずれかの評価式で算出し，ベイジアンアタックグラフの入力とする:

$$f_N = 2.11 \times AV_N \times AC_N \times PR_N \times UI_N \quad (3\text{-}1)$$

$$g_N = (34.0 - T_N - Ex_N - K_N - O_N - Eq_N)/34.0 \quad (3\text{-}2)$$

3.3 本研究の貢献

本提案手法による貢献は以下の通りである:

- 産業制御システムのリスク分析にベイジアンアタックグラフの手法を適用するにあたり，攻撃尤度を評価するために攻撃の特徴をどのように解釈し評価するかについて，新たな観点を提示する．
- ネットワークトポロジやシステム構成機器の能力などに合わせて CVSS のみで評価を行う先行研究に対し，機器のリバースエンジニアリング実施可能性など，攻撃者の能力や準備環境をより定義に近い条件で評価が行える Attack Potential を加味することができる．

次章では，本提案手法を用いたケーススタディを実施し実効性を検証すると共に，APT 攻撃などに象徴される複数の攻撃を重ねた攻撃を想定したリスク評価にあたっての，運用面での課題を示す．

4. ケーススタディ

以上の提案方式に対し，実際の攻撃事例を再構成した攻撃シナリオモデルを用いて分析の効果を示す．

4.1 システム構成と攻撃シナリオモデル

文献[13]では川西らが，2015 年にウクライナの電力グリッドに対しロシアのハッカー集団が起こした APT 攻撃の事例[14]を採り上げ，リスク評価を試みている．本論文でもこれをケーススタディとして提案手法の適用と課題抽出を試みた．システム構成を図 2 に示す．

本ケーススタディでは攻撃者がインターネット上におり，一連の APT 攻撃を実施する攻撃シナリオをモデル化した．本攻撃は以下の A～C のように 3 つのプロセスを経る：

A) 企業ネットワーク内の社員が利用する端末(以下社員 PC)にフィッシングなどの手段で侵入する．

B) OT 管理エリアへ発覚が困難な VPN 接続でアクセスする．A)で認証情報を窃取する場合と，そうでない場合の両方を考慮する．

C) OT 管理エリア内の潜伏調査の結果に基づき，比較的認証機能が弱いコントローラに不正アクセスする．そしてフィールド機器エリアのマシンへ誤作動を誘発するコマンドを送信し，攻撃を完遂する．

図 3 が上記 A～C のプロセスを描画したベイジアンアタックグラフである．各要素間をつなぐ矢印は有向で，矢印の基の原因と矢印の先の結果をつなぐことで，各要素間の因果関係を示す．各要素は文献[15]に従い，長方形と楕円とひし形の 3 種類を用いて構成する．まず長方形は攻撃者の能力や環境，システムのトポロジカルな構成や設定など，攻撃における前提条件を示す．次に楕円が原因に相当する各要素を結合する際に考慮する関係性やルールを示し，そしてそれに連なるひし形がもたらされた結果を示す．

図 3 の構成は，緑の線で囲ったエリアが前述のプロセス A，青線のエリアがプロセス B，赤線のエリアがプロセス C を示す．そして図上部の攻撃着手から図最下部の最終目標の攻撃完遂までが描画される．

各ノードの詳細について表 1 にまとめる．本ケーススタディでは，楕円のノードで原因側のノード(長方形もしくはひし形)を結合して尤度を算出するルールは“AND”もしく

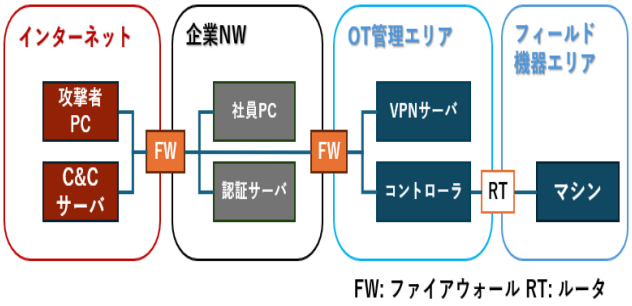


図2　ウクライナ電力グリッドのシステム構成

© 2026 Information Processing Society of Japan

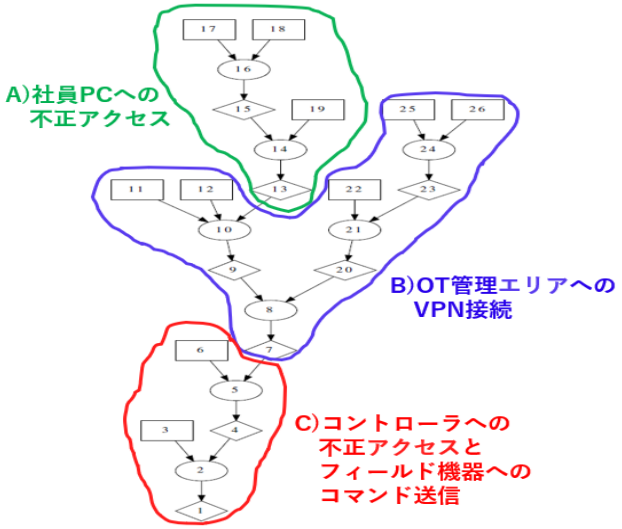


図3　ウクライナ電力グリッドのケースにおける
ベイジアンアタックグラフ

は“OR”のいずれかとし，以下の式(4-1)および式(4-2)でひし形のノードの尤度を求める:

$$P_{AND} = \prod_i Pi \quad (4\text{-}1)$$

$$P_{OR} = 1 - \prod_i (1 - Pi) \quad (4\text{-}2)$$

Pi: 原因側の各ノードの尤度

P_{AND}: AND ルールに繋がる結果の尤度

P_{OR}: OR ルールに繋がる結果の尤度

4.2　攻撃尤度の計算と環境変化に伴う値の推移

図 3 のベイジアンアタックグラフに提案手法を適用したものを図 4 の左端の図に示す．図 4 では図 3 で示したアタックグラフの各ノードに，3.2 節で示した提案手法に基づき計算した尤度を入力している．式(3-1)で計算した長方形ノードの尤度は青字で，式(3-2)で計算した長方形ノードの尤度は赤字としている．そして前述した“AND”もしくは“OR”のルールで合算したひし形のノードの尤度は黒字とした．

表1　ベイジアンアタックグラフ: ノードの説明

#	プロセス	分類	詳細
17	A)社員PCへの不正アクセス	前提条件	インターネットからメールが受信できる
18		前提条件	攻撃者のエントリーポイントは社外ネットワーク(スタート1)
16		ルール	AND
15		結果	社員PCが不正なマクロの載ったメールを受信
19		前提条件	メール添付の不正なマクロが実行される
14		ルール	AND
13		結果	攻撃者が社員PCに不正アクセスを実施
11	B)OT管理エリアへのVPN接続	前提条件	社員PCがVPNサーバのIPアドレスを持つ
12		前提条件	社員PCが認証情報を持つ
10		ルール	AND
9		結果	社員PCが経由でOT管理エリアへのVPN接続が成功
25		前提条件	VPN接続がインターネット上に開かれている
26		前提条件	攻撃者のエントリーポイントは社外ネットワーク(スタート2)
24		ルール	AND
23		結果	ネットワークスキャンによりVPN接続先を攻撃者が発見
22		前提条件	システム管理側の不備でVPN接続の認証情報がデフォルト
21		ルール	AND
20		結果	ネットワークスキャン結果と調査して得たデフォルトの認証情報を悪用して、OT管理エリアへのVPN接続が成功
8		ルール	OR
7		結果	攻撃者がVPN接続でOT管理エリアに侵入
6	C)不正アクセスとコマンド送信	前提条件	システム管理側の不備でコントローラの認証情報がデフォルト
5		ルール	AND
4		結果	攻撃者がコントローラに不正アクセスを実施
3		前提条件	フィールド機器が誤作動を起こす設定値を掌握
2		ルール	AND
1		結果	フィールド機器が誤作動を起こす(ゴール)

このように各ノードの値を入力・合算することで，一番下のノードであるゴール「フィールド機器が誤作動を起こす攻撃」が成功する尤度を推定している．

さて，4 つ並んだアタックグラフは左の初期状態から，3 つの環境の変化が順に加わった結果，どのように尤度が変遷するかを示すものである．便宜上以下のように t=t0, t1, t2, t3 として，詳細を記述する:

- **t=t0:** 変化が起きていない初期状態
- **t=t1:** 社員 PC に不正アクセスする手段が確立した
- **t=t2:** OT 管理エリアへの VPN 接続が確立した
- **t=t3:** コントローラと通信仕様が特定された

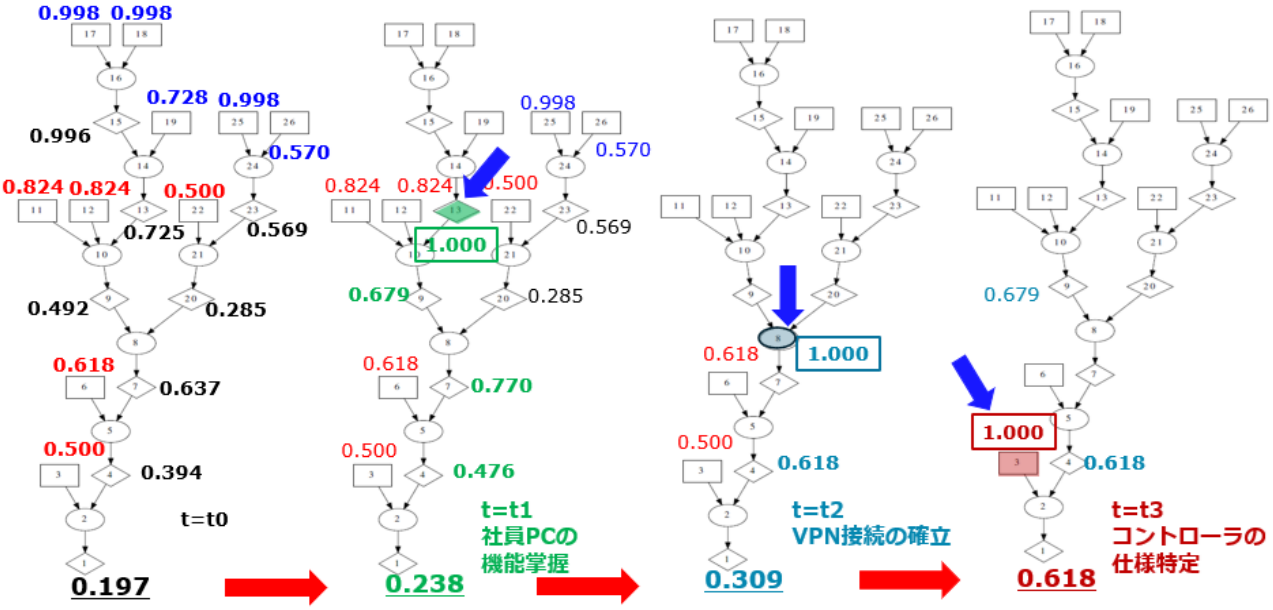


図4　ウクライナ電力グリッドのケースにおけるベイジアンアタックグラフと攻撃尤度の推移

© 2026 Information Processing Society of Japan

図 4 で示される緑色，水色，茶色の数値は環境 t=t1, t2 および t3 において，直前の環境と比較して変化した値を示す．

図 4 を見ると，攻撃が進むことで最終目標への攻撃成功率が上がっていくのが明らかとなる．開始時の t=t0 から VPN 接続確立の t=t2 までの攻撃経路は，社員 PC 経由(図 3 左側ノード 18 を起点とする経路)およびネットワークスキャンと市販の VPN サーバソフトの調査により見つけた IP アドレスやデフォルトの認証情報で VPN 接続を成功させる手段(図 3 右側ノード 26 を起点とする経路)の 2 通りあり，それぞれの攻撃尤度の差を数値で比較することが出来る．これによると，開始時の t=t0 の時は左側の経路で VPN 接続が確立できる尤度が 0.492 に対し，右側は 0.285 とおよそ 1.7 倍左側が有利であった．そして社員 PC へのフィッシングにより社員 PC の機能掌握を行えた t=t1 では左側の経路の尤度は 0.679 と，右側のおよそ 2.4 倍に有利と変化した．そして VPN 接続が確立された t=t2 の時は最終攻撃目標であるコントローラへの攻撃成功尤度は t=t0 の時の 0.197 から 0.309，およそ 1.6 倍に上昇した．

また t=t3 の時，コントローラ関連の仕様が特定されたことで攻撃成功尤度が大きく増加した．便宜上 t2 より後の時刻にしたが，例えば市販の同型のコントローラを購入しリバースエンジニアリングで調査が可能な機器であった場合，潜伏調査を行わずに事前に準備することも可能な前提条件であり，攻撃から守る場合に注意が必要な要因であることが明らかとなった．

図 5 のグラフに各ノードにおける尤度の変化を示す．赤線の“P1”の折れ線が最終目標であるコントローラへの攻撃成功の尤度である．他にも t=t0 の時に 0.725，t=t1 以降で 1 となる黄緑色の“P13”が社員 PC 機能掌握に成功する尤度のグラフであるなど，各ノードにおいて横軸 t に対する縦軸の尤度の変化の有無や程度がグラフで確認できる．

4.3 本提案方式の優位性

さて，3.1 節で先行研究として述べた，CVSS や EPSS のような脆弱性評価手法およびその拡張に対する，本提案方

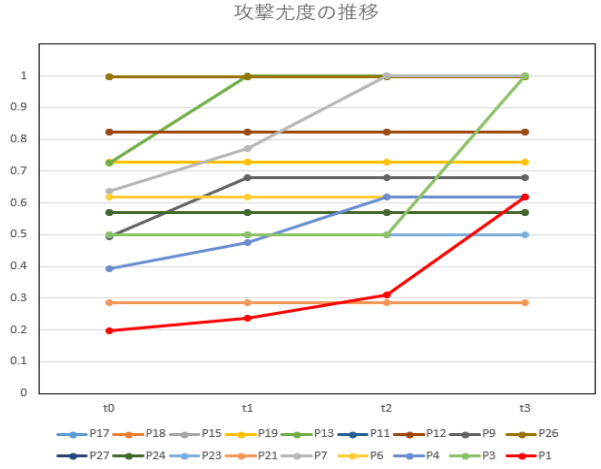


図5　環境変化に伴う攻撃尤度の推移

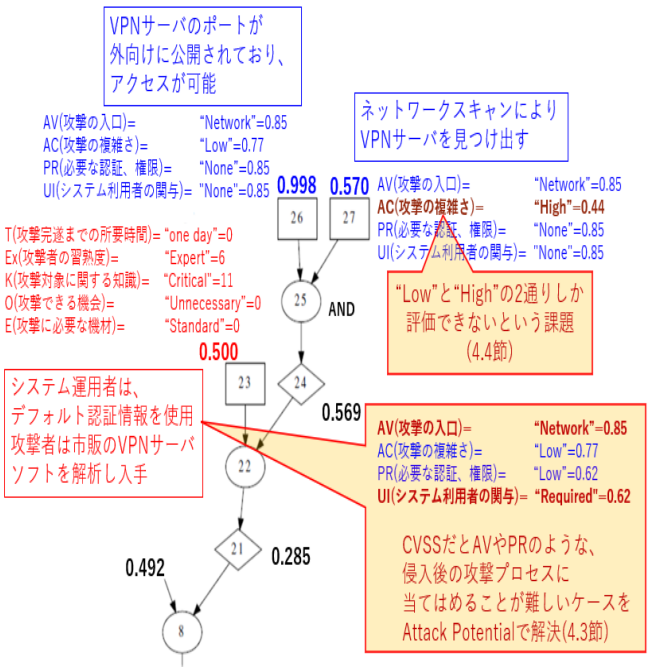


図6　攻撃プロセス評価の優位性と課題

式の優位性を述べる．図 6 は図 3 のアタックグラフの一部(ノード 21～26: ネットワークスキャンと市販の VPN サーバソフトの調査により見つけた IP アドレスやデフォルトの認証情報で VPN 接続を成功させる手段)であるが，これを例に説明する．

EPSS は評価式非公開の脆弱性評価手法なので比較対象から除外する．その他の先行研究では，新たなメトリックを評価に加えているものの，基本的に CVSS の評価式を使用している．図 6 ノード 26 と 27 の青字になっているのが CVSS で評価している部分である．

しかし CVSS は，ひとつの機器やひとつのシステムといった，ひとまとまりの対象を評価することが前提となっており，内部で分割された攻撃プロセスの評価には向いていない．例えば図 6 のノード 23 はシステムに侵入する際の認証情報の取得の容易性を評価するノードであるが，これを CVSS で評価しようと試みた場合，エントリーポイントの評価はノード 26 と 27 で評価済みで，かつ「システム運用者の問題で認証情報が取得しやすい」という事情を CVSS のメトリックで評価するのは困難である．図 6 の右下の例ではシステム利用者側の関与の有無を評価する UI で CVSS による解釈を試みているが，リバースエンジニアリングが可能かどうかについては妥当な解釈が出来ているとは言えない．

その点本提案方式であれば，ノード 23 を Attack Potential で評価することで,「ある程度の熟練者が認証情報という攻撃対象のかなり重要な情報を任意のタイミングで通常の装置で解析できる」というシステム内部での攻撃プロセスを評価できた．これが本提案方式の先行研究に対して持つ優位性である．APT 攻撃のような多段階のプロセスからなる複雑な攻撃を，中間段階で検知し追いかけ素早く対策を行

© 2026 Information Processing Society of Japan

うダイナミックリスクアセスメントに適していると考える．

本節で言及しなかった Attack Potential のメトリック T (Elapsed Time)に関しては，次節の課題で後述する．

4.4 本提案方式の課題

ケーススタディの結果に関し，課題が 2 点ある．

まずは評価式，特に CVSS の評価と実際の感触とのギャップについての課題である．本研究ではシステムのネットワークトポロジや通信インタフェースなどの属性に基づく攻撃容易性の評価では CVSS を選択しているが，それでも評価値と現実的な尤度とのギャップが懸念されるケースが今回のケーススタディでは起きていた．

前節で使用した図 6 の攻撃経路を再び用いて説明する．尤度を決めるノードは，ノード 26 (VPN サーバはインターネット上に公開されておりアクセス可能という環境: CVSS により尤度 0.998 と評価)，ノード 27 (ネットワークスキャンにより VPN サーバの IP アドレスとポート番号を特定: CVSS により尤度 0.570 と評価), およびノード 23(システム運用者がデフォルトの認証情報で VPN サーバを運用，従って攻撃者が VPN サーバソフトの調査により認証情報を入手できた: Attack Potential により尤度 0.500 と評価)である．そしてそれらの評価値が AND のルールで計算され，この経路で VPN 接続が成功する尤度が 0.285 となった．

一方で社員 PC への不正アクセスにより VPN サーバのアドレスと認証情報を得て VPN 接続が実現する尤度は 0.492 であり，こちらの方が有利であるが，その尤度の比が 1.7:1 程度と両者の尤度の違いが比較的僅かであることが現実と乖離している印象があった．

以上のような「尤度の違いが僅か」という結果により，提案方式における CVSS，Attack Potential 双方の解釈での課題が抽出される：

- **CVSS の課題:** VPN サーバの IP アドレスとポートを探す困難さを評価しようとしても, 攻撃の複雑さを評価するメトリックは粗い 2 段階評価しかできない“AC (Attack Complexity)”のみであること．そのため，攻撃の複雑さという観点での尤度に非常に差が付きづらい結果となっている．
- **Attack Potential の課題:** VPN サーバの認証情報を取得する困難さとして，VPN サーバに関するかなりの Knowledge of TOE (K)と相応の調査能力として Specialist Expertise (Ex)が必要と評価した．しかしこれらの評価の重みがあまり大きくないため, 尤度の差が付きづらい結果となっている．

  Attack Potential にて最も大きな値を取りうるメトリック T(Elapsed Time)であるが, 未知の攻撃を評価する際に値を決めづらいメトリックであるため, 多くのケースで最小値を取らざるを得ない. このため他のメトリックで評価しても，Attack Potential ベースの尤度は差が付きづらく，現実の感触とギャップが生じている．

CVSS や Attack Potential のような脆弱性評価手法の評価値を尤度に見立てた手法では，尤度は現実の確率と傾向は似ているが一致するものではないので，攻撃経路の比較に使用できれば問題ないという考えもある．しかし僅差で評価結果が逆転する状況も評価を誤らせる原因となりうる．そのためギャップを埋めるさらなる考察と，ランク数や数値の重みなど, 指標の追加を検討する必要があると考える．

5. ディスカッション

5.1 確率モデルの課題

本研究では先行研究[6]などの，脆弱性評価手法を攻撃の成功尤度に見立ててダイナミックリスクアセスメントを実施する手法を提案している．本提案手法は，多くの先行研究が選択している CVSS のメトリックの拡張した数値化手法ではなく, CVSS とは別の観点から脆弱性を評価する CC CEM 記載の Attack Potential をも導入し, 両者を使い分けることで攻撃経路の尤度の数値化を行っている．複数の数値化手法を組み合わせるという手法は先行例がなく，本提案手法の特徴としている．

本提案手法の課題としては, 4.4 節で述べたそれぞれの評価式を適用する際の課題の他，CVSS と Attack Potential をどのようなルールで併用するかという課題がある．

ひとつの考え方として, 本論文でのケーススタディでは, 以下のルールにより CVSS で評価するノードと Attack Potential で評価するノードを組み合わせるようにしている:

- CVSS は物理的もしくは論理的な境界を越えてモジュール間を移動する際の成功尤度を評価する．

  メトリック AV (Attack Vector)に関しては，実際の攻撃者が対象システムに対してどこから攻撃しているかで判断する. 例えばネットワーク経由でシステムに侵入後, そのままリモートで内部の他のモジュールにトラバースするのであれば, 次のモジュールへの侵入が有線経由であっても, AV のランクは “N (Network)”のまま変更しない．
- それ以外, モジュール侵入後のプロセスに対する攻撃に係るノードの評価は Attack Potential で実施する．

ケーススタディで課題として挙げた，CVSS における攻撃の複雑さが 2 通りしか評価できないという問題に関しては，川西らにより CVSS の代替として CWSS (Common Weakness Scoring System)[16]を適用したアプローチがある[13][17]. これにより前述の課題であった攻撃の複雑さを評価できる幅を拡大し，よりきめ細やかな攻撃の評価が実現した．従って同様に CWSS を適用することも今後の課題として検討する．

5.2 アタックグラフの課題

アタックグラフに関しては，抽象度と分析の精度との二

© 2026 Information Processing Society of Japan

律背反がある．システム設計段階で行われている従来手法の静的分析では，ある程度抽象度の高いモデルでシステム全体を俯瞰的に評価し，そこから必要なセキュリティ対策方針と関連する技術要件を洗い出すようにしていた．しかし本研究のようにダイナミックリスクアセスメントで複雑な攻撃を追跡したい場合，攻撃手段について具体性が不足すると評価が曖昧になり，環境の変化に即時対応できるような精度を持つことが出来ないという課題があった．

そのため本研究ではスコープをいくつかの攻撃シナリオに絞り，尤度評価の精度を上げるよう検討している．今後模擬システムによるシミュレーションを通じ，以下のようなより具体的な手法を検討していく予定である:

- レッドチーム/ブルーチーム演習のように攻撃側と防御側の対応とそれらが実施される順序を定め，時系列での尤度の変化を評価する．
- 攻撃への対応に行動を制約する条件を設ける．例えば工場システムにおいては，誤作動による事故だけでなく，操業停止も大きな問題となるので，攻撃が検知された際にどの段階で対策を行うかも検討する．
- 本研究では攻撃尤度に着目して進めてきたが，対策の優先順位を決めるのであれば，資産の評価も重要である．資産の評価についても複数の評価手法があるため，どれを適用するか検討する．

6. 結論

本研究ではベイジアンアタックグラフを活用したダイナミックリスクアセスメントに関し，その手法のひとつである脆弱性評価基準をベイジアンネットワークの確率モデルに見立てた，攻撃経路における尤度の比較評価という手法について検討を進めた．そして，従来手法では評価式の拡張により対応していた攻撃者に関する能力や環境の評価について，新たにコモンクライテリアの Attack Potential を組み合わせる手法を提案した．そして提案手法についてケーススタディを交え考察することで，ベイジアンアタックグラフを用いたリスク分析に新たな観点を加えた．

本論文における結論を以下に示す:

- 産業制御システムのリスク分析にベイジアンアタックグラフの手法を適用するにあたり，攻撃尤度を評価するための攻撃者についての観点を提示した．
- ネットワークトポロジやシステム構成機器の能力などに合わせ CVSS で評価を行う先行研究に対し，CVSS を拡張するだけでは不十分な部分，例えば未知の脆弱性の評価，攻撃の中途段階の個別評価，攻撃者の能力や環境の評価における課題を示した．
- 攻撃者の能力や準備環境の有無をより正確に評価できる，コモンクライテリアの Attack Potential に着目し，CVSS と組み合わせた手法を提案した．
- 計算式が取りうる値の精度や重みの違いなど，ケーススタディの評価を通じて本提案方式の課題を抽出し，今後の研究における実施方針を示した．
- 最後にディスカッションにおいて，評価式の使い方やベイジアンアタックグラフの粒度などのシステムへの攻撃手順のモデル化における課題を述べ，こちらも今後の研究における実施方針を示した．

参考文献

[1] A. Presekal, A. Ştefanov, V. S. Rajkumar, I. Semertzis, and P. Palensky: Advanced Persistent Threat Kill Chain for Cyber-Physical Power Systems, IEEE Access (2024).

[2] P. Cheimonidis and K. Rantos: Dynamic Risk Assessment in Cybersecurity: A Systematic Literature Review, Future Internet, MDPI (2023).

[3] L. Wang, S. Jajodia, and A. Singhal: Network Security Metrics, Springer (2017).

[4] S. Frei, M. May, U. Fiedler, and B. Plattner: Large-Scale Vulnerability Analysis, LSAD '06: Proceedings of the 2006 SIGCACOMM workshop on Large-scale attack defense (2006).

[5] C. Fruhwirth and T. Mannisto: Improving CVSS-based Vulnerability Prioritization and Response with Context Information, 2009 3rd International Symposium on Empirical Software Engineering and Measurement (2009).

[6] W. Yang, F. Hou, Z. Jia, H. Wang, Y. Yao, and P. Yin: A Dynamic Risk Assessment Method for Industrial Control Network Security Based on Bayesian Attack Graph, 2025 5th International Conference on Computer, Control and Robotics (ICCCR) (2025).

[7] Common Criteria: Common Methodology for Information Technology Security Evaluation (CEM:2022 Revision 1) (2022).

[8] P. Cheimonidis and K. Rantos: A Bayesian–Markov Framework for Proactive and Dynamic Cyber Risk Assessment Driven by EPSS, 2025 IEEE International Conference on Cyber Security and Resilience (CSR) (2025).

[9] X. Lyu, Y. Ding, and Shuang-Hua Yang: Bayesian Network Based C2P Risk Assessment for Cyber-Physical Systems, IEEE Access (2020).

[10] T. Wang, Q. Lv, Bo Hu, and D. Sun: CVSS-based Multi-Factor Dynamic Risk Assessment Model for Network System, 2020 IEEE 10th International Conference on Electronics Information and Emergency Communication (ICEIEC) (2020).

[11] M. U. Aksu, M. H. Dilek, E. İ. Tatlı, K. Bicakci, H. İ. Dirik, and M. U. Demirezen: A Quantitative CVSS-Based Cyber Security Risk Assessment Methodology for IT Systems, 2017 International Carnahan Conference on Security Technology (ICCST) (2017).

[12] S. Islam and A. Sand: The CVSS Deception: How We've Been Misled on Vulnerability Severity, Black Hat Europe 2024 (2024).

[13] 川西康之，西原秀明，吉田博隆，加藤勇夫，井上博之: 工場システムにおける APT 攻撃に注目したセキュリティリスク数値化手法の検討，コンピュータセキュリティシンポジウム 2025(2025).

[14] iTrust: BlackEnergy - Malware for Cyber-Physical Attacks (2016).

[15] D. Tayouri, N. Baum, A. Shabtai, and R. Puzis; A Survey of MulVAL Extensions and Their Attack Scenarios Coverage, IEEE Access (2023).

[16] Common Weakness Enumeration: Common Weakness Scoring System (CWSS) (online), available from <https://cwe.mitre.org/cwss/cwss_v1.0.1.html> (accessed 2026-08-20).

[17] Y. Kawanishi, H. Nishihara, H. Yoshida, H. Yamamoto, and H. Inoue: A Study on Threat Analysis and Risk Assessment Based on the “Asset Container” Method and CWSS, IEEE Access (2023).

© 2026 Information Processing Society of Japan